

Auditoría de hardening Proxmox VE (perfil bancario)

Cliente: **Banco Demo Paraguay S.A.** · Host: **pve_fake** · Fecha / Date: 2026-04-20 15:32 · Alcance: 7 controles sobre Web UI, SSH, cluster auth, firewall, patches

Riesgo agregado / Overall risk: **CRÍTICO**

Hash reproducibilidad / Reproducibility hash:
1e1bbab159a0107931d3436bc79b23e8338fe9e8ed61eca6428c8410a7b24d99

Separación de responsabilidades / Separation of duties: los veredictos (PASS/FAIL/N/A/ERROR) y la evidencia (comando ejecutado + output raw) provienen de motores determinísticos reproducibles. Las secciones marcadas **LLM NARRATIVA** son prosa explicativa generada por modelo de lenguaje y no modifican los veredictos ni la evidencia. Para defensibilidad regulatoria, el auditor debe basarse en la evidencia determinística.

Resumen ejecutivo

Se ejecutaron **7** controles sobre el host. Resultados: **6 FAIL**, **1 PASS**, 0 N/A, 0 ERROR. Nivel de riesgo agregado: **CRÍTICO**.

EN Executive summary. 7 controls executed on the host. Results: **6 FAIL**, **1 PASS**, 0 N/A, 0 ERROR. Overall risk: **CRÍTICO**. Framework: Proxmox VE Hardening Audit (banking profile). Scope: 7 controls covering Web UI, SSH, cluster auth, firewall, patching.

Control	Título	Sección	Veredicto	Severidad
PVE-2.1	SSH allows only key-based, non-root authentication	2	FAIL	CRITICAL
PVE-3.1	Multi-factor auth enforced for privileged Proxmox users	3	FAIL	CRITICAL
PVE-1.1	Web UI SSL certificate is CA-signed and not expired	1	FAIL	HIGH
PVE-3.2	Proxmox API tokens follow least-privilege + expiry	3	FAIL	HIGH
PVE-4.1	Datacenter firewall enabled with default-deny ingress	4	FAIL	HIGH
PVE-5.1	Proxmox version is supported and security patches applied	5	FAIL	MEDIUM
PVE-1.2	Privileged API endpoints require authentication	1	PASS	CRITICAL

Hallazgos / Findings

PCI PVE-2.1 — SSH allows only key-based, non-root authentication

FAIL

Sección 2 · Severidad CRITICAL · Host pve_fake

Evidencia determinística

Comando ejecutado: `sshd -T 2>/dev/null || cat /etc/ssh/sshd_config`

Hallazgos estructurados:

```
{
  "PermitRootLogin": "yes",
  "PasswordAuthentication": "yes",
  "PubkeyAuthentication": "yes",
  "ClientAliveInterval": "",
  "issues": [
    "PasswordAuthentication=yes (should be no)",
    "PermitRootLogin=yes (should be no)"
  ]
}
```

Remediación determinística (texto de la regla)

Edit /etc/ssh/sshd_config and set: PermitRootLogin no PasswordAuthentication no PubkeyAuthentication yes ClientAliveInterval 300 ClientAliveCountMax 2 Then: systemctl restart ssh. Validate a separate sudo-enabled account works BEFORE restarting.

Contexto (LLM)

LLM NARRATIVA El control PVE-2.1 es fundamental en entornos financieros que manejan datos de titulares de tarjetas, ya que el acceso SSH con autenticación basada en contraseñas o inicio de sesión como root crea vulnerabilidades de seguridad críticas. La configuración actual permite autenticación por contraseña y acceso root, lo cual viola directamente los requisitos de autenticación basada en claves. Esta configuración expone el sistema a riesgos de compromiso por fuerza bruta y ataques de tipo "privilege escalation".

Detalle de remediación (LLM)

LLM NARRATIVA La edición del archivo /etc/ssh/sshd_config debe realizarse con privilegios de root, asegurándose de que las líneas PermitRootLogin, PasswordAuthentication y PubkeyAuthentication se establezcan correctamente. El parámetro ClientAliveInterval debe configurarse en 300 segundos para mantener conexiones activas y ClientAliveCountMax en 2 para cerrar conexiones inactivas. Antes de reiniciar el servicio SSH, es esencial verificar que exista una cuenta con permisos sudo funcional para evitar bloqueos de acceso al sistema.

PCI PVE-3.1 — Multi-factor auth enforced for privileged Proxmox users

FAIL

Sección 3 · Severidad CRITICAL · Host pve_fake

Evidencia determinística

Comando ejecutado: `cat /etc/pve/domains.cfg 2>/dev/null ; cat /etc/pve/user.cfg 2>/dev/null`

Hallazgos estructurados:

```
{
  "realm_tfa": {
    "pam": false,
    "pve": false
  },
  "admin_users_no_tfa": [],
  "issues": [
    "realm 'pam' has no default-tfa",
    "realm 'pve' has no default-tfa",
    "root@pam has no TFA binding"
  ]
}
```

Remediación determinística (texto de la regla)

Web UI → Datacenter → Realm → edit realm → Default TFA: TOTP. Per-user: Datacenter → Permissions → Users → TFA column must show a method. Enforce on root@pam first. CLI reference: ``pveum user modify root@pam --keys ...``.

Contexto (LLM)

LLM NARRATIVA El control PVE-3.1 es fundamental en entornos bancarios y de datos de titulares de tarjetas, ya que requiere autenticación multifactor para usuarios privilegiados de Proxmox. La falta de autenticación multifactor en los usuarios administrativos representa un riesgo crítico de acceso no autorizado a sistemas críticos. Este fallo permite que un atacante que obtenga credenciales válidas pueda acceder sin restricciones a infraestructura virtual sensible.

Detalle de remediación (LLM)

LLM NARRATIVA Para corregir, se debe configurar TOTP como método predeterminado de autenticación multifactor en los realms 'pam' y 'pve' a través de la interfaz web. El usuario root@pam debe ser el primero en tener habilitado TFA, lo cual se realiza en la sección de permisos de usuarios. La configuración se puede validar mediante el comando CLI ``pveum user modify root@pam --keys`` para asegurar que el método de autenticación multifactor esté correctamente asignado.

PCI PVE-1.1 — Web UI SSL certificate is CA-signed and not expired

FAIL

Sección 1 · Severidad HIGH · Host pve_fake

Evidencia determinística

Comando ejecutado: openssl x509 -in /etc/pve/local/pve-ssl.pem -noout -subject -issuer -dates -pubkey 2>&1

Hallazgos estructurados:

```
{
  "subject": "CN = pve01.demo.bank.local",
  "issuer": "CN = pve01.demo.bank.local",
  "not_before": "Apr 20 15:27:17 2026 GMT",
  "not_after": "Jul 19 15:27:17 2026 GMT",
  "self_signed": true,
  "days_to_expiry": 89,
  "issues": [
    "Certificate is self-signed (subject == issuer)"
  ]
}
```

Remediación determinística (texto de la regla)

Replace the default self-signed cert. From the Web UI → Datacenter → Certificates → Upload Custom (or ACME for public). CLI: `pvenode cert set --force <cert.pem> <key.pem>`. Ensure RSA >= 2048 bits or ECDSA P-256. Set up auto-renewal.

Contexto (LLM)

LLM NARRATIVA El control PVE-1.1 es fundamental en entornos bancarios y de datos de titulares de tarjetas, ya que garantiza la autenticidad y confidencialidad de las comunicaciones HTTPS en la interfaz web del servidor. Un certificado autofirmado no cumple con los requisitos de seguridad, ya que no puede ser verificado por autoridades de certificación reconocidas, lo que expone el sistema a riesgos de suplantación y escucha no autorizada. Este fallo representa una vulnerabilidad de alta gravedad que compromete la integridad de la infraestructura de seguridad.

Detalle de remediación (LLM)

LLM NARRATIVA La solución consiste en reemplazar el certificado autofirmado por uno emitido por una autoridad de certificación reconocida, utilizando la interfaz web o el comando CLI proporcionado. Es necesario asegurar que el certificado cumpla con requisitos criptográficos mínimos de 2048 bits RSA o ECDSA P-256 para mantener la protección adecuada. Además, se debe implementar un proceso automatizado de renovación para evitar la expiración inesperada del certificado y mantener la continuidad del servicio.

PCI PVE-3.2 — Proxmox API tokens follow least-privilege + expiry

FAIL

Sección 3 · Severidad HIGH · Host pve_fake

Evidencia determinística

Comando ejecutado: `stat -c '%a %U %G' /etc/pve/priv/token.cfg 2>/dev/null ; cat /etc/pve/priv/token.cfg 2>/dev/null`

Hallazgos estructurados:

```
{
  "mode": "644",
  "owner": "root",
  "group": "root",
  "tokens_total": 2,
  "tokens_no_expiry": 2,
  "tokens_root_pam": 2,
  "tokens_privsep_off": 2,
  "issues": [
    "2 token(s) bound to root@pam",
    "2 token(s) with no expiry",
    "2 token(s) with privsep=0 (inherits full perms)",
    "token.cfg world-permissions != 0 (mode 644)"
  ]
}
```

Remediación determinística (texto de la regla)

Store tokens under a dedicated non-root realm user: ``pveum user add ci@pve --password ...``.
Issue token with privsep: ``pveum user token add ci@pve ciops --privsep 1 --expire <unix-ts>``.
Enforce chmod 640 root:www-data on /etc/pve/priv/token.cfg. Rotate tokens yearly.

Contexto (LLM)

LLM NARRATIVA El control PVE-3.2 es crucial en entornos bancarios que manejan datos de titulares de tarjetas, ya que los tokens de API mal configurados pueden proporcionar acceso no autorizado a sistemas críticos. La ausencia de expiración y el uso de privilegios completos para tokens vinculados a root@pam representan riesgos elevados de compromiso. Este fallo permite que credenciales persistentes sean explotadas por atacantes con acceso a los sistemas Proxmox.

Detalle de remediación (LLM)

LLM NARRATIVA Se debe crear un usuario dedicado llamado ci@pve para gestionar tokens de forma segura, evitando el uso directo de credenciales root. Los tokens deben ser emitidos con privsep=1 para limitar permisos y establecer fechas de expiración válidas. El archivo token.cfg debe tener permisos 640 con propietario root y grupo www-data para restringir el acceso a procesos web solo. Se recomienda rotar los tokens al menos una vez al año para mantener la seguridad.

PCI PVE-4.1 — Datacenter firewall enabled with default-deny ingress

FAIL

Sección 4 · Severidad HIGH · Host pve_fake

Evidencia determinística

Comando ejecutado: pve-firewall status 2>&1 || true ; cat /etc/pve/firewall/cluster.fw 2>/dev/null

Hallazgos estructurados:

```
{
  "status": "disabled/not running",
  "enable": "0",
  "policy_in": "ACCEPT",
  "issues": [
    "cluster.fw enable=0 (need 1)",
    "policy_in=ACCEPT (need DROP/REJECT)",
    "pve-firewall status=disabled/not running"
  ]
}
```

Remediación determinística (texto de la regla)

Web UI → Datacenter → Firewall → Options: Firewall=Yes, Input Policy=DROP, Output Policy=ACCEPT. Then enable per-node: Node → Firewall → Options: Firewall=Yes. Audit rules on each VM. CLI: edit /etc/pve/firewall/cluster.fw.

Contexto (LLM)

LLM NARRATIVA El control PVE-4.1 es fundamental en entornos bancarios y de datos de tarjetas, ya que un firewall de datacenter con política de denegación por defecto en ingreso (default-deny ingress) limita el acceso no autorizado a los sistemas críticos. La configuración actual con firewall deshabilitado y política de entrada ACCEPT crea una brecha de seguridad significativa que podría permitir accesos no autorizados a la infraestructura de procesamiento de pagos. Esta falla representa un riesgo alto de violación de la confidencialidad y disponibilidad de los datos sensibles de los titulares de tarjetas.

Detalle de remediación (LLM)

LLM NARRATIVA Para corregir esta configuración, se debe habilitar el firewall a nivel de datacenter mediante la interfaz web en Datacenter → Firewall → Options, estableciendo Firewall=Yes y Input Policy=DROP. Posteriormente, es necesario activar el firewall en cada nodo individualmente a través de Node → Firewall → Options con Firewall=Yes. Finalmente, se deben revisar y auditar las reglas de firewall en cada máquina virtual para garantizar que solo se permitan los accesos necesarios según las políticas de seguridad establecidas.

PCI PVE-5.1 — Proxmox version is supported and security patches applied **FAIL**

Sección 5 · Severidad MEDIUM · Host pve_fake

Evidencia determinística

Comando ejecutado: pveversion --verbose 2>&1 | head -5 ; apt-get -s -o
Debug::NoLocking=true upgrade 2>/dev/null | grep -c '^Inst ' || echo 0

Hallazgos estructurados:

```
{  
  "version": "7.2.0",  
  "pending_upgrades": 42,  
  "issues": [  
    "42 package upgrades pending",  
    "Proxmox 7.2 is EOL (support ended 2024-07)"  
  ]  
}
```

Remediación determinística (texto de la regla)

Run `apt update && apt dist-upgrade -y` on a maintenance window. Major upgrades: follow official PVE 7→8 guide. Enable the no-subscription repo only for dev; prod banking must use pve-enterprise repo with support contract.

Contexto (LLM)

LLM NARRATIVA El control PVE-5.1 es crucial en entornos bancarios que manejan datos de titulares de tarjetas, ya que un sistema virtualizado desactualizado representa un riesgo significativo de vulnerabilidades no parcheadas. La versión 7.2.0 de Proxmox ha alcanzado su fin de vida útil (EOL) en julio de 2024, lo que significa que ya no recibe soporte ni parches de seguridad oficiales. La presencia de 42 paquetes pendientes de actualización aumenta la superficie de ataque y puede comprometer la integridad del entorno de procesamiento de pagos.

Detalle de remediación (LLM)

LLM NARRATIVA La ejecución de `apt update && apt dist-upgrade -y` debe realizarse durante una ventana de mantenimiento programada para evitar interrupciones en servicios críticos. Para actualizaciones mayores como la de PVE 7 a 8, es obligatorio seguir la guía oficial de actualización proporcionada por Proxmox. En entornos de producción bancaria, solo se debe habilitar el repositorio no suscrito para desarrollo; el entorno de producción debe utilizar exclusivamente el repositorio pve-enterprise con contrato de soporte vigente.

PCI PVE-1.2 — Privileged API endpoints require authentication

PASS

Sección 1 · Severidad CRITICAL · Host pve_fake

Evidencia determinística

Comando ejecutado: `curl -sk -m 5 -o /dev/null -w '%{http_code}' <endpoints>`

Hallazgos estructurados:

```
{
  "endpoints": {
    "/api2/json/version": "200",
    "/api2/json/nodes": "401",
    "/api2/json/cluster/status": "401",
    "/api2/json/access/domains": "401",
    "/api2/json/access/users": "401"
  },
  "issues": []
}
```

Remediación determinística (texto de la regla)

If endpoints respond 200 without auth, something has tampered with PVEAPIServer ACLs. Inspect /etc/pve/datacenter.cfg for 'notify' or custom auth, revert, then: systemctl restart pveproxy pvedaemon. Verify TLS is active on port 8006 — if not, API traffic is in cleartext.

Contexto (LLM)

LLM NARRATIVA El control PVE-1.2 es crucial en entornos bancarios que manejan datos de titulares de tarjetas, ya que los puntos de acceso privilegiados de la API de Proxmox Virtual Environment (PVE) pueden ser explotados por atacantes para obtener acceso no autorizado a recursos críticos. La autenticación obligatoria para estos endpoints previene la exposición de información sensible y mantiene la integridad del entorno virtualizado. Este control forma parte fundamental de las medidas de seguridad necesarias para cumplir con los estándares PCI-DSS v4 en ambientes de procesamiento de pagos.

Detalle de remediación (LLM)

LLM NARRATIVA Si los endpoints responden con código 200 sin autenticación, indica una modificación no autorizada de los controles de acceso ACL del servidor PVE. Es necesario revisar el archivo /etc/pve/datacenter.cfg en busca de configuraciones personalizadas o notificaciones que puedan estar comprometiendo la seguridad. Después de revertir cualquier cambio indebido, se debe reiniciar los servicios pveproxy y pvedaemon para aplicar las nuevas políticas de autenticación. Además, es esencial verificar que el tráfico API esté cifrado en el puerto 8006, ya que el tráfico en texto plano representa un riesgo significativo para la confidencialidad de los datos de los titulares de tarjetas.

Apéndice A — Evidencia cruda / Appendix A — Raw evidence

Comandos ejecutados y output stdout/stderr sin procesar. Permite reproducir manualmente cada hallazgo / Commands executed and raw stdout/stderr, enabling manual reproduction of every finding.

PCI PVE-2.1 — SSH allows only key-based, non-root authentication

Comando

```
sshd -T 2>/dev/null || cat /etc/ssh/sshd_config
```

stdout (raw)

```
# This is the sshd server system-wide configuration file. See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/bin:/usr/bin:/bin:/usr/games

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented. Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
```

stderr (raw)

```
#HostKey /etc/ssh/ssh_host_rsa key
#HostKey /etc/ssh/ssh_host_ecdsa key
#HostKey /etc/ssh/ssh_host_ed25519 key
```

PCI PVE-3.1 — Multi-factor auth enforced for privileged Proxmox users

Comando

```
#Ciphers and keying
#RekeyLimit default none

cat /etc/pve/domains.cfg 2>/dev/null ; cat /etc/pve/user.cfg 2>/dev/null
#Logging
#SyslogFacility AUTH
```

stdout (raw)

```
#Authentication: realm-tfa ===
{'pam': False, 'pve': False}
#LoginGraceTime 2m
PermitRootLogin yes
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

stderr (raw)

```
PubkeyAuthentication yes
(vacio)
# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2
```

PCI PVE-1.1 — Web UI SSL certificate is CA-signed and not expired

Comando

```
#AuthorizedPrincipalsFile none
openssl x509 -in /etc/pve/local/pve-ssl.pem -noout -subject -issuer -dates -pubkey 2>&1
```

stdout (raw)

```
subject=CN = pve01.demo.bank.local
issuer=CN = pve01.demo.bank.local
notBefore=Apr 20 15:27:17 2026 GMT
notAfter=Jul 19 15:27:17 2026 GMT
```

```
-----BEGIN PUBLIC KEY-----
MIIBIjANBgqhkiG9w0BAQEFAA0CAQ8AMIIBCgKCAQEAwWjNn0aXxujLiD0bLI7g
c/7wUIqGEsFMxmp73xp8LnZwc4PGWjZ2KHJTJjid04KA9oKgDG1ik8fVVh94+LCN
6XipPaGa+fQJl03UuGTuld23g4vaCDlbnxT8ZTS7ct5bJGfodqm20DB2RMyvqayR
89KVT3cvRwfVP2WDH+ekp8GAbQuPdGdADovIwUizMOURiKoQJqVf20q98H5otxsC
K+pJE+seEagEeFgbqC//iKrjk6zqW6/nis4gI3kQDqtuUM0d0SEJZraIad3M4KU8
EZqFsH0xnY6YpsUYCq+/J2+jBL1vT9t+b3rZNAZ0k218slrmaA2EY6Ug0tx00Ewo
iQIDAQAB
-----END PUBLIC KEY-----
```

stderr (raw)

```
(vacío)
```

PCI PVE-3.2 — Proxmox API tokens follow least-privilege + expiry

Comando

```
stat -c '%a %U %G' /etc/pve/priv/token.cfg 2>/dev/null ; cat /etc/pve/priv/token.cfg 2>/dev/
null
```

stdout (raw)

```
stat: 644 root root
```

```
file excerpt:
```

```
root@pam!backup:0:0:automated nightly backups:
```

```
root@pam!monitoring:0:0:zabbix integration:
```

stderr (raw)

PCI PVE-4.1 — Datacenter firewall enabled with default-deny ingress

Comando

```
pve-firewall status 2>&1 || true ; cat /etc/pve/firewall/cluster.fw 2>/dev/null
```

stdout (raw)

```
=== pve-firewall status ===
Status: disabled/not running
Firewall enabled:      0
```

```
=== cluster.fw [OPTIONS] ===
```

```
enable: 0
```

```
policy_in: ACCEPT
```

```
policy_out: ACCEPT
```

stderr (raw)

PCI PVE-5.1 — Proxmox version is supported and security patches applied

Comando

```
pveversion --verbose 2>&1 | head -5 ; apt-get -s -o Debug::NoLocking=true upgrade 2>/dev/null |  
grep -c '^Inst ' || echo 0
```

stdout (raw)

```
=== pveversion ===  
proxmox-ve: 7.2-1 (running kernel: 5.15.39-1-pve)  
pve-manager/7.2-3/c743d6c1 (running version: 7.2-3/c743d6c1)  
pve-kernel-5.15: 7.2-3  
  
=== pending upgrades ===  
42
```

stderr (raw)

PCI PVE-1.2 — Privileged API endpoints require authentication

Comando

```
curl -sk -m 5 -o /dev/null -w '%{http_code}' <endpoints>
```

stdout (raw)

```
{  
  "/api2/json/version": "200",  
  "/api2/json/nodes": "401",  
  "/api2/json/cluster/status": "401",  
  "/api2/json/access/domains": "401",  
  "/api2/json/access/users": "401"  
}
```

stderr (raw)

```
(vacío)
```

Este reporte se considera válido únicamente acompañado del artifact JSON cuyo SHA-256 coincide con 1e1bbab159a0107931d3436bc79b23e8... Cualquier modificación del JSON invalida este reporte. Generado por Kryon compliance engine.

This report is valid only alongside the JSON artifact whose SHA-256 matches the hash above. Any modification to the JSON invalidates this report.